

Security Principles

- 1) Consider the procedure. If someone calls `withdrawal(-10)`, the balance increases by 10 without any problem. What principle is violated here?

```
procedure withdrawal(w)
    // contact central server to get balance
    1. let b := balance

    2. if b < w, abort

    // contact server to set balance
    3. set balance := b - w

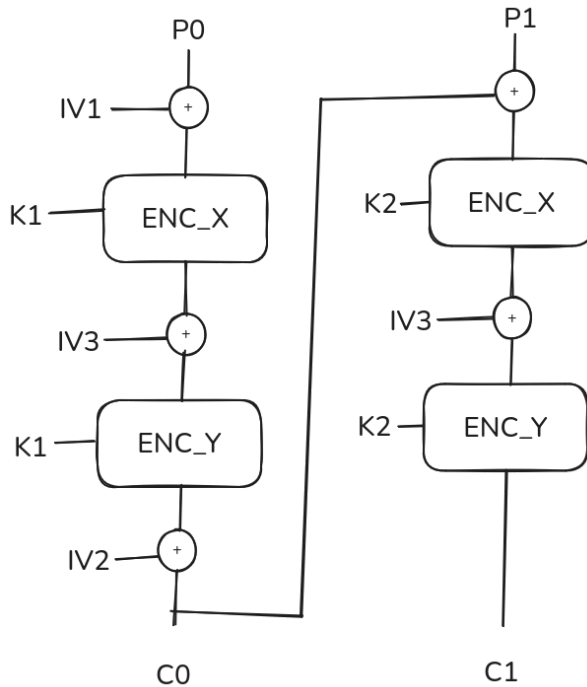
    4. give w dollars to user
```

- 2) Alice and Bob decide to communicate with each other in a secret encryption mechanism. Since only the two of them are communicating, they do not bother creating any secret key. The mechanism is secret and that should be enough. What principle does it violate?
- 3) The referer header in a cookie is absent, and now the server has to decide if it should respond to the request or not. If it does, then there is a chance of CSRF attack. If it drops the request then there might be a legitimate user who gets denied service. What principle should be considered here?

Cryptography

- 1) If the key to a one time pad is incremented after each use instead of being completely random, then will it be secure? Explain
- 2) Your friend sent you an encrypted message with AES-CBC. The ciphertext is of the form (IV, C1 || C2 || C3 || ... || Cn). You do not have an AES-CBC decryptor. You have an AES-ECB decryptor program. How would you decrypt the message?
- 3) Recall the PKCS#7 padding scheme and compare it with the padding scheme of appending a 1 and padding with 0s. Compare in terms of correctness and memory efficiency.
- 4) If instead of randomizing IV in each message, it is incremented by 1 in AES-CBC, will it be secure? Explain
- 5) Find a generic way to design a stream cipher with any AES encryption (e.g. AES-CBC, AES-CFB etc)
- 6) Explain when stream ciphers will be parallelizable in both encryption and decryption
- 7) A message and key is being hashed together in format $H(\text{message} || \text{key})$. Is it possible to perform a length extension attack here?
- 8) In Diffie-Hellman key exchange, the prime number p is chosen to be 7. What are the possible primitive root values (g) the protocol can choose?

- 9) Mallory wants to modify $(C0, C1, IV1, IV2, IV3)$ to $(C0', C1', IV1', IV2', IV3')$ so that Bob does not receive $(P0, P1)$, instead he receives $(P0', P1')$



- 10) If both ENC_X and ENC_Y are one time pads, then find out the decryption equations.

CSRF, XSS, SQLi

- 1) In the Kabir search engine, Mallory found that when she searches for “cat” the result is shown in the url kabir.com/search?q=cat. She has her suspicion that the result is fetched with a query “SELECT url FROM searches WHERE title like \$input”. Each entry in the searches table has fields - url and date. She also noticed that the result page starts with “10,000 results found for cat”. Also 100 most recent searches made by all users are shown in a table. Design attack for -
- Performing a stored XSS (no other attack is allowed)
 - Performing a reflected XSS (no other attack is allowed)
 - Making “catto” the most recent search item forever (well, almost forever)

Memory Safety Vulnerabilities

```

1) int main(void) {
    char buf[12] = ?;
    int *a = malloc(4);
    int b;
    printf(buf);
    assert(*a == 2005000); // *a should be 2005000 here
    return 0;
}
  
```

- 2) Explain why off-by-one exploits get trickier if after returning to the caller function, the caller function uses its local variables sometimes before finally returning itself.
- 3) How does memory overflow in use-after-free scenarios cause shellcode injection through function pointers or vtables?

Network attacks

- 1) ARP is a stateless protocol, meaning it does not remember the requests pending (answers yet to arrive). So any received ARP replies are cached, even if no request was sent (there is no way to know if a request was made or not, as it is a stateless protocol). Then explain how in ARP spoofing, Mallory succeeds after winning the race condition against Bob, as right after Mallory's lie arrives, Bob's legitimate response arrives and the legitimate one is cached.
- 2) Discuss which threat models (off path, on path, MITM) succeed to attack in -
 - a) ARP spoofing
 - b) DHCP spoofing
 - c) TCP spoofing
 - d) DNS spoofing
- 3) Explain how WPA-Enterprise is still vulnerable to attacks such as ARP or DHCP spoofing
- 4) In TLS, what does the server send in the Certificate stage? Let's say server says - "my public key is x and CA#1 signed this. Here is the signature - ..." But what if the client does not know or trust CA#1 directly but perhaps through the public key infrastructure somehow? How does he verify then?
- 5) Compare DNSSEC and DNS over TLS